

Clase 275 — Seguridad de dispositivos médicos

Parte: **13 — Seguridad móvil, IoT e inalámbrica** · Fuente: *Practical IoT Hacking* (Chantzis et al.), FDA Premarket Cybersecurity Guidance y estándares AAMI/IEC 80001 🕒 Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Comprender los riesgos de ciberseguridad únicos de los dispositivos médicos —donde un fallo puede causar daño físico directo a un paciente— y cómo se evalúan y regulan. El alumno estudiará la superficie de ataque de dispositivos implantables (marcapasos, bombas de insulina) y hospitalarios (bombas de infusión, monitores), los estándares y regulaciones aplicables (FDA, IEC 62304/80001, MDR), y el marco ético/legal que hace de esta un área especialmente sensible.

⚠️ **Nota ética y legal crítica:** JAMÁS pruebes dispositivos médicos en uso clínico, conectados a pacientes o ajenos. La investigación legítima se realiza sobre unidades de laboratorio propias, retiradas de servicio, o mediante programas de divulgación coordinada con el fabricante. El daño potencial es a vidas humanas.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

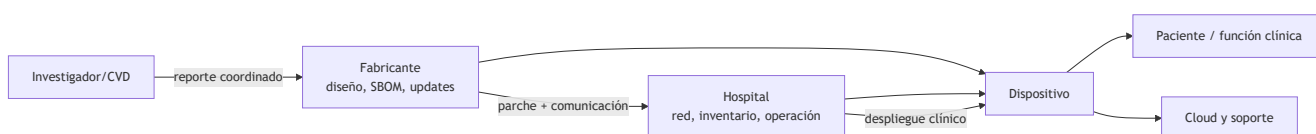
1. **Describir** la superficie de ataque de dispositivos médicos implantables y hospitalarios.
2. **Explicar** por qué los sistemas médicos priorizan seguridad del paciente (safety) y disponibilidad.
3. **Identificar** vulnerabilidades históricas reales y su impacto.
4. **Aplicar** el marco regulatorio (FDA, IEC 62304, IEC 80001, MDR) a un caso.
5. **Ejecutar** divulgación coordinada de vulnerabilidades de forma responsable.
6. **Recomendar** controles alineados con guías de la FDA y AAMI.

#	Tema	Por qué importa
1	Panorama y safety vs. security	El riesgo es daño físico al paciente
2	Dispositivos implantables	Telemetría inalámbrica y batería
3	Dispositivos hospitalarios	Red clínica, bombas, monitores
4	Vulnerabilidades históricas	Lecciones de casos reales
5	Regulación (FDA, IEC, MDR)	Marco de cumplimiento obligatorio
6	SBOM y gestión de parches	Ciclo de vida largo y difícil de parchear
7	Divulgación coordinada	Cómo reportar sin causar daño

Explicación en profundidad

El riesgo de ciberseguridad se traduce a daño clínico

Un dispositivo médico puede incluir hardware, software, red hospitalaria, servicio remoto y procesos humanos. La pregunta no termina en «¿puede explotarse?»: se rastrea si una pérdida de integridad, disponibilidad o confidencialidad altera terapia, alarma, diagnóstico o continuidad, y qué controles clínicos limitan el daño. Seguridad y eficacia permanecen durante todo el ciclo de vida.



La guía final de FDA de febrero de 2026 aborda diseño, sistema de calidad y contenido de presentaciones previas a mercado para dispositivos con riesgo de ciberseguridad. La legislación estadounidense aplicable a *cyber devices* incluye planes para vulnerabilidades, procesos de actualización y SBOM; fuera de EE. UU. cambian obligaciones. La clase usa FDA como fuente primaria concreta, no como norma mundial.

Parchar exige comprobar compatibilidad, validación y ventana clínica. Aplazar indefinidamente tampoco es neutral: se documentan riesgo residual y mitigaciones como segmentación, deshabilitar funciones o monitorizar. El fabricante mantiene divulgación coordinada y soporte; el hospital inventario, configuración, red y respuesta; ninguna parte puede trasladar todo el riesgo a la otra.

Las pruebas se realizan en gemelos, simuladores o dispositivos retirados y descontaminados, sin conexión a pacientes ni redes clínicas. Un hallazgo se comunica coordinadamente y evita detalles que aumenten daño antes de existir mitigación.

Caso razonado: parche disponible, aplicación clínica pendiente

El fabricante publica una corrección para un monitor. El hospital no la instala de inmediato porque requiere validación con su central, pero segmenta el equipo, bloquea acceso remoto y programa ensayo. Registra riesgo y plazo. La decisión no es «seguridad contra disponibilidad»: es gestión temporal con controles y evidencia clínica.



Glosario operativo

Término	Definición útil
Cyber device	Categoría legal estadounidense definida por FD&C Act; no todo dispositivo mundial.
TPLC	Gestión del producto durante diseño, mercado, soporte y retiro.
SBOM	Inventario de componentes que acelera evaluación, sin demostrar seguridad.
CVD	Divulgación coordinada de vulnerabilidades.
Daño clínico	Consecuencia sobre paciente, diagnóstico, terapia o continuidad.



Criterio de dominio

El alumno domina la clase cuando conecta una amenaza con una consecuencia clínica, reparte responsabilidades, diseña parche y mitigación temporal y prepara divulgación sin probar sobre pacientes ni producción.



Definiciones y características

- **Dispositivo médico implantable (IMD):** dispositivo dentro del cuerpo (marcapasos, DAI) con telemetría inalámbrica. Característica: restricciones severas de energía y de seguridad del paciente.
- **Bomba de infusión:** dispositivo que administra fármacos; frecuentemente en red. Característica: una manipulación de dosis puede ser letal.
- **Safety vs. security:** safety protege al paciente de fallos; security protege de ataques. Característica: en medicina, security es un requisito de safety.
- **IEC 62304:** estándar del ciclo de vida del software de dispositivos médicos. Característica: exige gestión de riesgos del software.
- **IEC 80001:** gestión de riesgo de dispositivos médicos en redes de TI. Característica: gobierna su integración hospitalaria.
- **SBOM (Software Bill of Materials):** inventario de componentes de software. Característica: la FDA lo exige para rastrear vulnerabilidades de terceros.



Herramientas y preparación

- **Solo unidades de laboratorio propias / retiradas de servicio** o simuladores; nunca dispositivos clínicos activos.
- Técnicas heredadas de esta parte: análisis de firmware (267), hardware UART/JTAG (268), SDR (269) y BLE (271) aplicadas éticamente.
- Documentación regulatoria: FDA guidance, MDS2 (Manufacturer Disclosure Statement for Medical Device Security).

Enfoque de esta clase: mayormente conceptual, regulatorio y de proceso.

El laboratorio práctico consiste en análisis de caso, modelado de amenazas

y redacción de un informe de divulgación coordinada – NO en atacar hardware médico real.

Laboratorio guiado

Este laboratorio es de **análisis y proceso**, no ofensivo sobre hardware clínico.

1. **Elige un caso público** documentado (p. ej. vulnerabilidades divulgadas en bombas de infusión o marcapasos) a partir de avisos de la FDA/ICS-CERT (CISA).
2. **Modela la amenaza:** identifica activos (paciente, dosis, telemetría), vectores (RF, red, físico) y consecuencias de safety.
3. **Mapea la superficie de ataque** por capas (app clínica, red hospitalaria, RF del implante, firmware) reutilizando el enfoque de la clase 266.
4. **Evalúa controles existentes:** cifrado de telemetría, autenticación, límites de dosis codificados por hardware, watchdog.
5. **Aplica el marco regulatorio:** relaciona el caso con requisitos de la guía de la FDA, IEC 62304 y IEC 80001.
6. **Redacta una divulgación coordinada:** simula un informe responsable dirigido al fabricante (impacto, reproducción a alto nivel, plazo, sin exploit público).
7. **Propón mitigaciones:** SBOM, segmentación de red clínica, actualizaciones firmadas, límites de seguridad físicos.

Ejercicios

1. Enumera la superficie de ataque de un marcapasos con telemetría inalámbrica.
2. Explica por qué en medicina la seguridad es un requisito de safety.
3. Resume una vulnerabilidad médica real divulgada y su impacto potencial.
4. Relaciona un hallazgo con IEC 62304 e IEC 80001.
5. Redacta un borrador de aviso de divulgación coordinada.
6. Diseña un límite de seguridad de hardware que evite una sobredosis por software.

Reto verificable

Elabora un **informe de evaluación de riesgo y divulgación coordinada** para un dispositivo médico (basado en un caso público o una unidad de laboratorio propia). **Criterio de aceptación:** el informe incluye un modelo de amenazas con al menos tres vectores, mapea cada riesgo a un requisito regulatorio concreto (FDA/IEC), y propone un proceso de divulgación responsable con plazos, sin publicar ningún exploit funcional.

Errores comunes

Síntoma / problema	Causa y cómo abordarlo
Probar hardware clínico activo	Riesgo a vidas y delito; usa solo unidades de laboratorio o análisis de casos
Tratar security y safety por separado	En medicina se integran; modela ambas juntas
Publicar el exploit sin coordinar	Puede causar daño; sigue divulgación coordinada con el fabricante
Ignorar el ciclo de vida largo	Dispositivos operan décadas; planifica parcheo y SBOM
Asumir red aislada	Los hospitales están cada vez más conectados; aplica IEC 80001

Preguntas frecuentes

? ¿Por qué la seguridad de dispositivos médicos es diferente de otro IoT? Porque el impacto es directo sobre la salud y la vida del paciente, el ciclo de vida es larguísimo, el parcheo es difícil (requiere revalidación clínica) y hay regulación estricta.

? ¿Puedo investigar la seguridad de un dispositivo médico legalmente? Sí, sobre unidades propias/retiradas de servicio y siguiendo divulgación coordinada. Muchos fabricantes tienen programas de reporte. Nunca sobre dispositivos conectados a pacientes.

? ¿Qué papel juega el SBOM? Permite saber qué componentes de terceros usa el dispositivo para reaccionar cuando aparece una vulnerabilidad en una librería, algo crítico dado su ciclo de vida prolongado.

Referencias

- FDA — Cybersecurity in Medical Devices, guía final vigente: <https://www.fda.gov/regulatory-information/search-fda-guidance-documents/cybersecurity-medical-devices-quality-management-system-considerations-and-content-premarket>
- CISA ICS Medical Advisories: <https://www.cisa.gov/news-events/cybersecurity-advisories>
- IEC 62304 e IEC 80001 (ciclo de vida y gestión de riesgo en red).
- Practical IoT Hacking*, secciones de dispositivos médicos — Chantzis et al.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 274 — Seguridad automotriz y bus CAN](#)

Siguiente clase

[Clase 276 — Gobernanza de la seguridad de la información](#)